

PROSPECT & LEAD DATA

DATA HANDLING POLICY

A GRC portfolio project by Glenda de Guzman | Version 1.0 | Scope: personal data collected through common B2B sales outreach and enrichment tools (e.g. ZoomInfo, LinkedIn Sales Navigator, Clay, Apollo.io, generic CRM)

1. Purpose

This policy sets out how personal data belonging to prospects and leads is collected, stored, used, shared, retained, and disposed of during outbound and inbound B2B sales activity. It exists to protect prospect privacy, reduce the organization's regulatory exposure, and give staff a clear, consistent standard to follow.

2. Scope

This policy applies to all personal data obtained through sales intelligence and enrichment platforms, LinkedIn outreach, cold email, and CRM records, and to every staff member who accesses, exports, or acts on that data as part of lead generation or account management.

3. Definitions

- **Personal data:** any information that identifies or can identify an individual, including name, work email, direct phone number, job title, and employer.
- **Processing:** any action taken on personal data, including collection, storage, enrichment, use in outreach, and deletion.
- **Approved vendor:** a data or analytics tool that has passed the organization's Vendor Due Diligence Questionnaire.

4. Data Classification

Prospect and lead records are classified as Confidential. The table below sets the classification tiers used across sales operations.

Classification	Examples	Handling rule
Public	Company name, general service description shared with prospects	No restriction
Internal	Aggregate pipeline reports, campaign performance metrics	Staff and management only, not shared externally
Confidential (prospect personal data)	Prospect name, work email, direct phone, job title, LinkedIn URL	CRM and approved vendor tools only, least privilege access, never exported to personal devices or unapproved spreadsheets

5. Collection Principles

- Collect only the fields needed to qualify and contact a prospect: name, title, employer, work email, and, where relevant, direct phone.
- Source contact data only from vendors that appear on the Approved Vendor List (see Section 8).

- Do not collect personal mobile numbers, home addresses, or any data unrelated to the prospect's professional role.

6. Storage and Access Control

- Prospect data is stored only in the designated CRM (Zoho CRM or equivalent) and the sanctioned enrichment tools, never in personal spreadsheets, notes apps, or personal cloud storage.
- Access is granted on a least privilege basis, limited to staff actively working the relevant campaign or account.
- Multi factor authentication is required on all CRM and vendor tool accounts that hold prospect data.

7. Retention and Disposal

- Prospect records with no engagement after 12 months are reviewed and removed from active outreach lists.
- A prospect who unsubscribes or requests removal is deleted from active CRM records and outreach tools within 5 business days.
- Exported lists (spreadsheets used for a single campaign) are deleted once the campaign concludes and the results are logged in the CRM.

8. Third Party Sharing and the Approved Vendor List

- Prospect data is shared only with vendors that have completed the Vendor Due Diligence Questionnaire and, where applicable, signed a Data Processing Agreement.
- No prospect data is shared with a vendor or partner outside this approved list without written sign off from the business owner.

9. Data Subject Requests

- A prospect who asks what data is held, or asks for it to be corrected or deleted, is treated as a valid request regardless of the channel it arrives through (email reply, LinkedIn message, phone call).
- Requests are actioned within 5 business days and logged for audit purposes.

10. Incident Reporting

- Any suspected exposure of prospect data (a lost device, a misdirected export, a vendor breach notice) is reported to the business owner immediately, not held until confirmed.
- The business owner determines whether affected individuals or a regulator must be notified, consistent with applicable law.

11. Roles and Responsibilities

- Business owner: approves new vendors, owns this policy, and is the first point of contact for incidents.
- Staff handling prospect data: follow this policy, complete due diligence before adopting a new tool, and report concerns promptly.

12. Review Cycle

This policy is reviewed annually, or immediately following a change in vendor tooling, a data incident, or a relevant change in privacy law.

Appendix: Mapping to ISO/IEC 27001:2022

Included to show how each section of this policy maps to a recognized control, for internal audit reference and for demonstrating framework literacy in job applications.

Policy clause	ISO/IEC 27001:2022 Annex A control	What it covers
Section 4, Data Classification	A.5.12 Classification of information	Labeling data by sensitivity so handling rules are consistent
Section 5, Collection Principles	A.5.34 Privacy and protection of PII	Collecting only what is needed, from approved sources
Section 6, Storage and Access	A.8.3 Information access restriction / A.5.15 Access control	Least privilege, MFA on CRM and vendor tools
Section 7, Retention and Disposal	A.8.10 Information deletion	Defined retention windows and secure deletion
Section 8, Third Party Sharing	A.5.19 to A.5.23 Supplier relationships	Approved vendor list, DPA required before onboarding
Section 10, Incident Reporting	A.5.24 Incident management planning	Who to notify and how fast, when a breach is suspected